

SEMANA 10: MITIGACIÓN Y DEFENSA ACTIVA

Sistemas de Comunicación y Seguridad Informática

Aplicación de controles técnicos, bastionado de servidores (*hardening*) y estrategias de parcheo.

Mg. Gabriel Guerrero Arellano

AGENDA

¿Qué haremos en estas 2 horas?



Ubicación:

Momento 3 (Ataque, Defensa y Auditoría).



Conceptos Clave:

Bastionado (*Hardening*), Controles Técnicos, Gestión de Parches y Defensa Activa.



Herramientas:

Docker, Nginx Config (Rate Limiting) y Apache Benchmark (`ab`).



Laboratorio Práctico:

Fortificación de un servidor web para neutralizar el ataque DoS (HTTP Flood) probado en la Semana 9.



Evidencia:

Reporte de mitigación exitosa mediante el bloqueo de tráfico malicioso (Códigos HTTP 503 / 429).

CAMBIO DE ROL

Del Ataque (Semana 9) a la Defensa (Semana 10)

1

En la Semana 9 actuamos como atacantes saturando los recursos de un servidor no fortificado mediante inundación HTTP.

2

Hoy asumimos el rol de Administradores de Seguridad / SysAdmins.

3

El objetivo no es apagar el servidor ni bloquear usuarios legítimos, sino aplicar controles para absorber o rechazar ataques en tiempo real preservando la disponibilidad.

HARDENING

Bastionado de Servidores (*Server Hardening*)

- **Definición:** Proceso continuo de asegurar un sistema reduciendo su superficie de ataque vulnerable.

- **Principios fundamentales:** Principio de mínimo privilegio, deshabilitar servicios/puertos innecesarios y ocultar firmas de software.

- **Impacto:** Transforma una instalación por defecto (insegura por naturaleza) en un entorno resistente a escaneos y ataques automatizados.



CONTROLES

Arquitectura de Controles Técnicos



Controles Preventivos:

Detienen el acceso malicioso antes de que afecte la aplicación (ej. Firewalls, WAF, Rate Limiting).



Controles Detectivos:

Identifican anomalías e intentos de intrusión en tiempo real (ej. IDS/IPS, análisis de logs).



Controles Correctivos:

Aíslan la amenaza y restauran la operación tras un incidente (ej. aislamiento de contenedores, despliegue de parches).

PARCHEO

El Ciclo Vital de Parcheo

La realidad operativa: La mayoría de brechas exitosas explotan vulnerabilidades conocidas (CVEs) que ya cuentan con parches oficiales.

Estrategia de remediación: Escaneo constante de dependencias (SCA/Trivy), priorización por severidad y despliegue automatizado.

Principio Zero Trust en Infraestructura: Actualizar continuamente las imágenes base del sistema operativo e imágenes Docker.



CVEs



SCA/Trivy



Severidad



Imágenes Docker

Defensa Activa: Limitación de Tasa (*Rate Limiting*)

01

¿Qué es?:

Técnica para restringir la cantidad de peticiones que una misma IP o cliente puede realizar en un intervalo de tiempo.

02

Mecanismo en Capa 7:

Si una IP supera el umbral tolerado (ej. 5 peticiones/segundo), el servidor responde inmediatamente con un error `503 Service Unavailable` o `429 Too Many Requests` sin procesar el contenido pesado.

03

Ventaja:

Protege la CPU y la RAM del servidor frente a ataques HTTP Flood y ataques de fuerza bruta.

MITIGACIÓN

El Ciclo de Mitigación

Identificamos el vector de ataque (Inundación HTTP de Capa 7).

Diseñamos la política de bastionado (Restricción por zona y cuotas por IP).

Aplicamos la configuración fortificada en el servidor web.

Sometemos la infraestructura a estrés extremo para validar el bloqueo del tráfico excedente.



HERRAMIENTAS

Arsenal de Defensa de Hoy

Pasemos de la teoría a la práctica. ¿Qué herramientas utilizaremos para bastionar nuestro entorno?

LABORATORIO

Las Herramientas del Laboratorio

Docker:

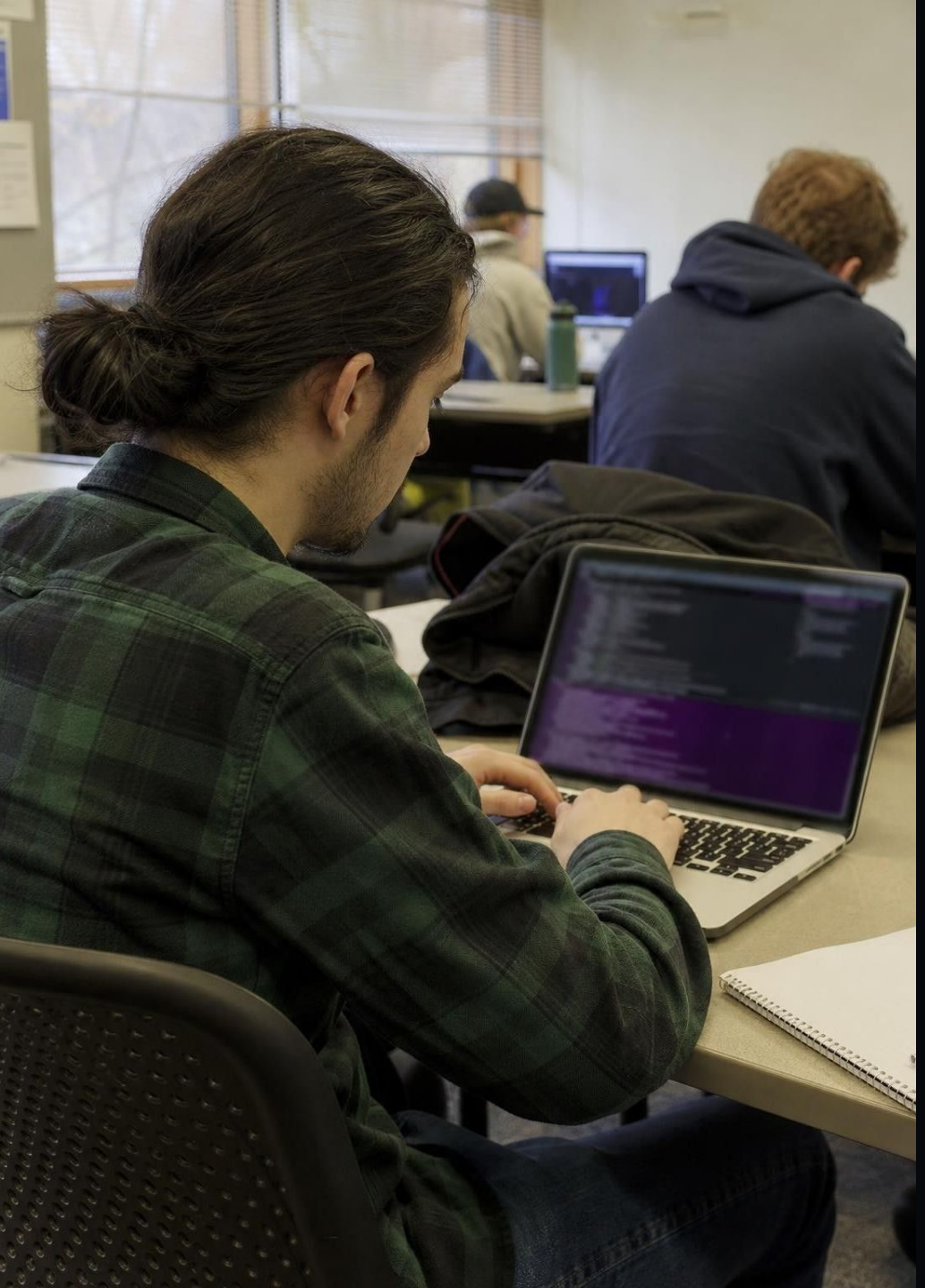
Reutilizamos nuestro entorno de contenedores para aislar la infraestructura.

Nginx (`ngx_http_limit_req_module`):

Motor servidor web configurado con políticas de mitigación activa.

Apache Benchmark (`ab`):

Generador de tráfico para simular el ataque de inundación y certificar la efectividad de la defensa.



LABORATORIO PRÁCTICO

Laboratorio Práctico: Bastionado y Mitigación en Acción

Objetivo: Configurar un servidor Nginx con reglas estrictas de Rate Limiting para detener el ataque HTTP Flood de la Semana 9, logrando que el servidor bloquee la ráfaga maliciosa mientras mantiene el servicio activo.

SIMULACIÓN

¿Qué estamos simulando exactamente?



El Ataque (El Agresor)

Simulamos la acción de un bot, un script automatizado o una herramienta de pruebas de estrés (ApacheBench `ab`) intentando tumbar nuestro servidor web enviándole una ráfaga agresiva de **1,000 peticiones casi en simultáneo** (50 peticiones concurrentes por segundo).



La Defensa (El Bastionado con *Rate Limiting*)

En lugar de dejar el servidor web abierto a recibir tráfico ilimitado (como en la Semana 9), implementamos un "portero inteligente" en la configuración de Nginx. Definimos una cuota máxima tolerable de tráfico por dirección IP (`rate=5r/s` con un margen de ráfaga de `burst=10`).



El Comportamiento de la Infraestructura

Simulamos la resiliencia de un servidor de producción fortificado frente a un ataque de fuerza bruta estructural.

Fase 0: Validación de Entorno Paso a Paso

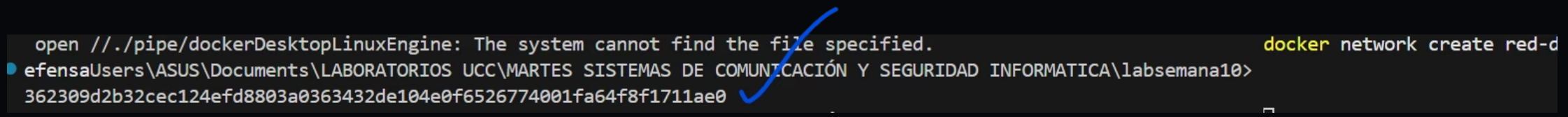
Atención a todos: No avanzamos al Paso 1 hasta confirmar estos comandos en la terminal.

01 Validar Docker activo abrir el entorno de docker desktop: `docker --version`

02 Crear red virtual aislada: `docker network create red-defensa`

03 Crear carpeta de trabajo local y entrar en ella:

- En Linux/Mac/Git Bash: `mkdir labsemana10 && cd labsemana10`
- En Windows (PowerShell): `mkdir labsemana10` y luego `cd labsemana10`



PASO 1

Paso 1: Configuración de Bastionado (nginx.conf)

- Crea un archivo llamado nginx.conf dentro de la carpeta lab-semana10 usando tu editor (Visual Studio Code).
- Pega este contenido exacto de configuración segura:

```
events { worker_connections 1024; }
http {
    limit_req_zone $binary_remote_addr zone=zona_defensa:10m rate=5r/s;
    server {
        listen 80;
        root /usr/share/nginx/html;
        index index.html;

        location / {
            limit_req zone=zona_defensa burst=10 nodelay;
        }
    }
}
```

PASO 2

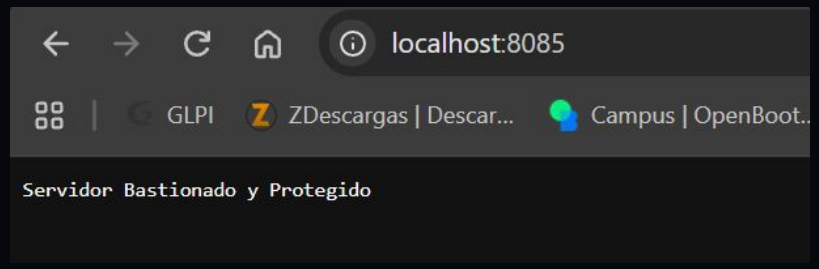
Paso 2: Encendiendo el Servidor Bastionado

Lanza el contenedor Nginx inyectando tu archivo de bastionado:

En Windows (PowerShell):

```
docker run -d --name servidor-bastionado --network red-defensa -v
"${PWD}\nginx.conf:/etc/nginx/nginx.conf:ro" -p 8085:80 nginx
```

Validación en navegador: Abre `http://localhost:8085`. Debe responder: "Servidor Bastionado y Protegido".



PASO 3

Paso 3: Lanzando la Prueba de Estrés y Bloqueo

01 Abre una nueva pestaña en la terminal (Terminal del Atacante).

02 Entra a la red en un contenedor temporal: `docker run -it --rm --network red-defensa alpine sh`

03 Instala la herramienta de ataque: `apk add apache2-utils`

04 Dispara una ráfaga masiva: `ab -n 1000 -c 50 http://servidor-bastionado/`

05 **Resultado:** Observa cómo el reporte muestra una gran cantidad de `Non-2xx responses` (peticiones bloqueadas con error 503). ¡El servidor repelió el ataque automáticamente!

ANÁLISIS TÉCNICO

¿Qué ocurrió técnicamente tras lanzar el ataque (ab)?

Cuando lanzamos el comando `ab -n 1000 -c 50 http://servidor-bastionado/`, la herramienta disparó **1,000 peticiones HTTP en ráfaga concurrente (50 al mismo tiempo)** hacia nuestro servidor.

12

Permisos y Cuota Inicial (12 peticiones 200 OK)

Gracias a la regla `rate=5r/s` con tolerancia de `burst=10 nodelay`, Nginx atendió únicamente las primeras **12 peticiones legítimas** dentro de la ventana de tiempo.

988

Activación del Escudo (988 Non-2xx responses)

Las **988 peticiones restantes** superaron de inmediato la cuota permitida por la IP atacante. En lugar de procesar la página o saturar la memoria y el procesador, el motor de Nginx cortó la conexión entregando un código de respuesta **`503 Service Unavailable`**.

0.290 s

Eficiencia de Procesamiento (0.290 segundos)

Rechazar una petición a nivel de servidor toma microsegundos. El servidor procesó la ráfaga a **3,450 peticiones por segundo**, descartando el tráfico malicioso sin consumir recursos computacionales significativos.

PEDAGOGÍA

¿Qué hemos demostrado?

Con este laboratorio demostramos **los 3 pilares de la Defensa Activa y el Bastionado de Servidores (*Hardening*)**:

01

Efectividad del Bastionado en Capa 7 (Aplicación)

Demostramos que no se necesita apagar el servidor ni instalar hardware costoso para frenar un ataque DoS; un control técnico bien configurado a nivel de servidor web (como *Rate Limiting*) neutraliza el 98.8% del impacto de forma automática.

02

Preservación de la Disponibilidad (Triada CIA)

A diferencia del laboratorio de la Semana 9 (donde el servidor no fortificado sufrió latencia y congelamiento), hoy demostramos resiliencia: **el atacante recibe respuestas `503` (bloqueado), mientras que el usuario real desde el navegador entra a `http://localhost:8085` y ve la página al instante (`200 OK`).**

03

Diferencia entre Falla del Servidor y Defensa Activa

En la herramienta de auditoría, las peticiones aparecen como *"Failed requests"*, no porque el servidor colapsó, sino porque el servidor **decidió rechazar activamente al agresor**. La seguridad funcionó exacto como fue diseñada.